Compliance Annotation

CloudArc Solutions, Inc.

Framework: SOC 2 | Compliance Level: Fully Compliant

Finding 1: [COMPLIANT] Governance and Security Oversight (CC1.1-CC1.5) CloudArc maintains a robust governance structure featuring a Code of Conduct signed by all employees at hire and reviewed annually. Oversight is managed by a CISO-chaired Security Steering Committee that meets quarterly, with semi-annual briefings provided to the Board of Directors. Security responsibilities are formally documented and integrated into performance evaluations. **References:** CC1.1, CC1.2, CC1.3, CC1.4, CC1.5

Finding 2: [COMPLIANT] Comprehensive Risk Management (CC3.1-CC3.4) The organization performs a detailed annual risk assessment and updates it following significant environmental changes. This process includes a specific evaluation of fraud risk factors and is supported by a risk register that is reviewed quarterly by the Steering Committee. **References:** CC3.1, CC3.2, CC3.3, CC3.4, CC9.1

Finding 3: [COMPLIANT] Logical Access and Identity Management (CC6.1-CC6.3) Access follows the principle of least privilege, utilizing role-based access control (RBAC) and mandatory multi-factor authentication (MFA) via Okta. Quarterly access reviews ensure permissions remain current, and access is revoked within 24 hours of a user's termination or role change. Privileged access is strictly monitored and requires CISO approval. **References:** CC6.1, CC6.2, CC6.3

Finding 4: [COMPLIANT] Data Protection and Encryption Standards (CC6.1, C1.1) CloudArc enforces AES-256 encryption for all data at rest and TLS 1.2 or higher for data in transit. Security is enhanced through AWS KMS for automated annual key rotation and the use of tenant-specific keys to ensure logical data separation. **References:** CC6.1, C1.1

Finding 5: [COMPLIANT] Change Management and Deployment Integrity (CC8.1) Changes are strictly managed through a lifecycle involving Jira documentation, mandatory peer reviews, and testing in staging environments. Material changes require Change Advisory Board (CAB) approval, while all deployments utilize automated CI/CD pipelines with documented rollback plans. **References:** CC8.1

Finding 6: [COMPLIANT] Incident Response and Monitoring (CC7.3-CC7.5) Continuous 24/7 monitoring is performed via Datadog and CrowdStrike to detect anomalies. The organization maintains a documented Incident Response Plan (IRP), undergoes semi-annual tabletop exercises, and commits to notifying affected customers within 72 hours of a confirmed breach. **References:** CC7.3, CC7.4, CC7.5

Finding 7: [COMPLIANT] Platform Availability and Disaster Recovery (A1.1-A1.3) CloudArc guarantees a 99.9% uptime SLA through multi-region AWS deployment (us-east-1 and eu-west-1). Availability is supported by daily cross-region backups, quarterly disaster recovery testing, and an aggressive 4-hour RTO and RPO. **References:** A1.1, A1.2, A1.3

Finding 8: [COMPLIANT] Centralized Logging and SIEM Operations (CC7.2) All system, application, and administrative logs are aggregated in Splunk with a 12-month retention period. Log integrity is preserved through immutable storage, and automated alerts are triggered for any anomalous activity. **References:** CC7.2

Finding 9: [COMPLIANT] Third-Party and Vendor Risk Management (CC9.2) Vendors accessing customer data must provide a current SOC 2 Type II report and pass a standardized security risk questionnaire. Contracts mandate a 24-hour breach notification window and include right-to-audit clauses. **References:** CC9.2

Finding 10: [COMPLIANT] Privacy and Data Subject Rights (P1-P8) The privacy notice clearly outlines data practices and provides users with in-app tools to access, correct, or request the deletion of their personal data. Data is deleted within 90 days of account termination to fulfill storage limitation requirements. **References:** P1.1, P2.1, P3.1, P4.1, P5.1, P6.1, P7.1, P8.1

Finding 11: [COMPLIANT] Vulnerability Management and Remediation (CC7.1) Automated weekly scans and annual independent penetration tests identify system vulnerabilities. CloudArc adheres to strict remediation SLAs: 24 hours for critical, 7 days for high, and 30 days for medium severity issues, supplemented by a bug bounty program. **References:** CC7.1

Finding 12: [COMPLIANT] Security Awareness and Technical Training (CC1.4) Mandatory hire and annual security training is enforced for all employees, with specialized secure coding modules for developers. Quarterly phishing simulations are conducted to maintain workforce vigilance. **References:** CC1.4